



Fairfield University

GenAI Under Attack

Evaluating Enterprise Security Gaps Against Emerging AI Threat Vectors

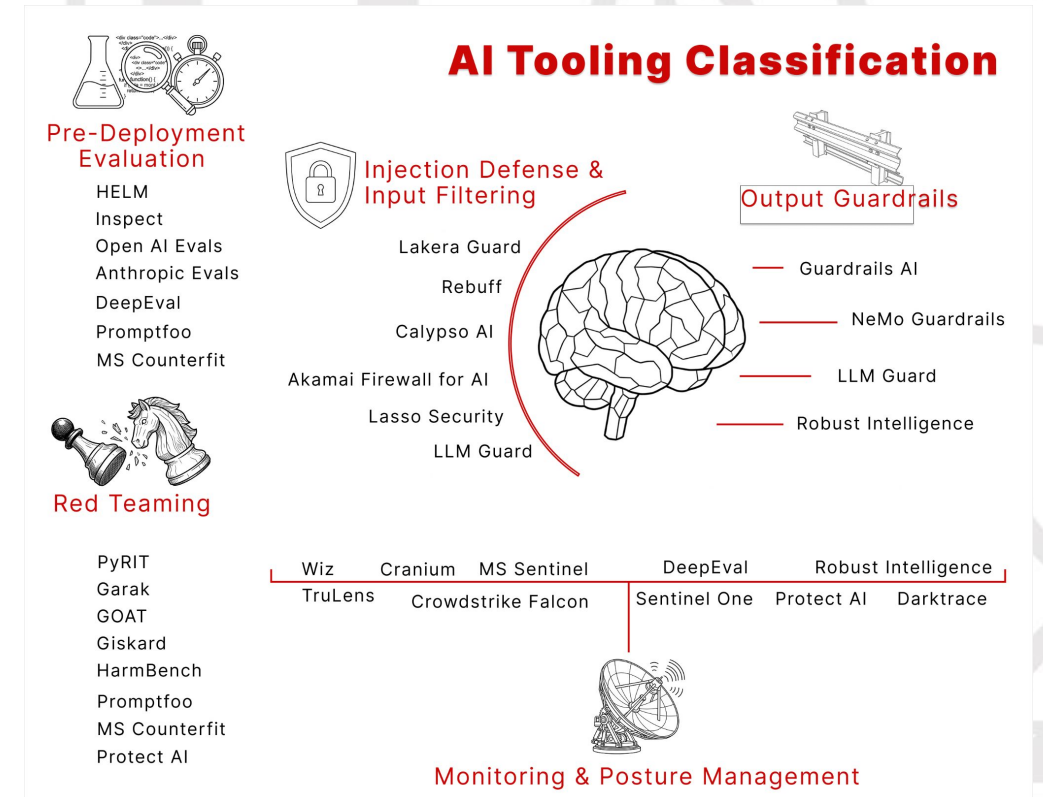
Red Teaming Generative AI (GenAI)

Ronald Bradford, Michael Goger, Amir Alibali

Project Need: GenAI Creates a New Enterprise Attack Surface

PROBLEM STATEMENT

- GenAI adoption fundamentally expands the attack surface area beyond what traditional web, cloud, and infrastructure defenses address.
- Existing cybersecurity frameworks were not designed to address prompt-based, model-based, or agentic attack paths.
- Organizations lack standardized procedures to detect, test, monitor, and respond to AI-specific threats quickly and at scale.
- AI-assisted red teaming can support continuous, deeper testing across internal and external GenAI use cases.



Project Objectives

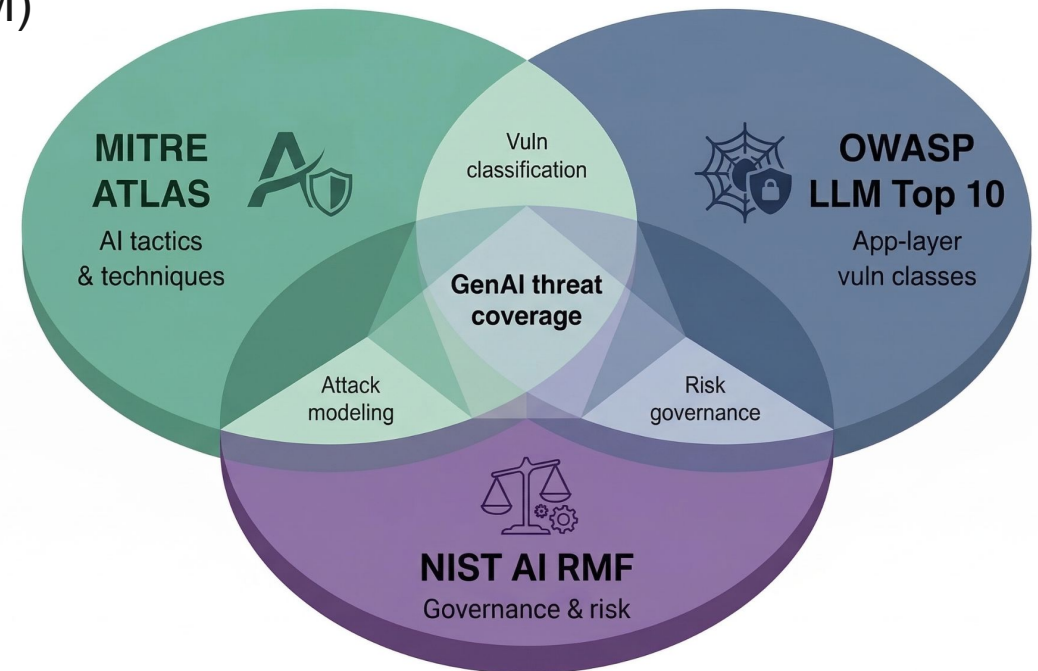
WHAT THE PROJECT SET OUT TO DO

- Identify and categorize GenAI-specific attack threat vectors absent from existing cybersecurity frameworks.
- Map coverage gaps using OWASP LLM Top 10, MITRE ATLAS, and NIST AI RMF relative to the current GenAI threat landscape.
- Evaluate the effectiveness of existing controls including guardrails, input/output validation, and least-privilege access against real-world GenAI attack scenarios.
- Recommend a structured, layered mitigation strategy practitioners can operationalize across the full GenAI deployment lifecycle.

Output: Symposium poster highlighting predefined strategies, tactics, and procedures for testing and handling AI-system vulnerabilities.

GenAI Foundational Frameworks

- MITRE **A**dversarial **T**hreat **L**andscape for **AI** **S**ystems (MITRE ATLAS)
- The **O**pen **W**orldwide **A**pplication **S**ecurity **P**roject (OWASP)
 - Top 10 Risks for Large Language Models (LLM)
- NIST **AI** **R**isk **M**anagement **F**ramework (AI RMF)



OWASP - Top 10 Risks for LLMs

#	Code	Category	2017	2021	2025	Trend
1	A01	Broken Access Control <i>incl. SSRF rolled in (2025)</i>	#5	#1	#1	↑↑
2	A02	Security Misconfiguration <i>incl. XXE absorbed (2021)</i>	#6	#5	#2	↑↑↑
3	A03	Software Supply Chain Failures <i>expanded from Vulnerable & Outdated Components</i>	#9	#6	#3 ★	↑↑↑
4	A04	Cryptographic Failures <i>was Sensitive Data Exposure</i>	#3	#2	#4	↓
5	A05	Injection <i>incl. XSS (2021+); SQL, NoSQL, OS, LDAP</i>	#1	#3	#5	↓↓

N ★ New or significantly expanded category

merged Removed / consolidated in that cycle

↑ Rising ↓ Declining → Stable

<https://owasp.org/www-project-top-ten/>

OWASP - Top 10 Risks for LLMs

ID	Vulnerability Name	Practical Description	Real-World Example
A01	Broken Access Control	Users acting outside their intended permissions. This now includes SSRF.	<i>Changing a user ID parameter in a URL (e.g., /account?id=123 to id=124) to view another person's private billing details.</i>
A02	Security Misconfiguration	Missing security hardening, relying on default configurations, or improper cloud permissions.	<i>Leaving a default admin password (admin/admin) active on a production server, or keeping an AWS S3 bucket open to the public.</i>
A03	Software Supply Chain Failures	Vulnerabilities arising from compromised third-party code, dependencies, or build environments.	<i>A popular open-source package you rely on is compromised by an attacker who injects a backdoor, infecting your app during the build process.</i>
A04	Cryptographic Failures	Failures to adequately protect sensitive data in transit or at rest.	<i>Transmitting credit card numbers over plain HTTP or storing user passwords using an outdated, easily cracked hashing algorithm like MD5.</i>
A05	Injection	Untrusted user data is sent to an interpreter as part of a command or query, altering its execution.	<i>A user inputs ' OR 1=1 -- into a login field, tricking the SQL database into granting them access without a valid password.</i>

Download this handout from <https://ronaldbradford.github.io/capstone/>

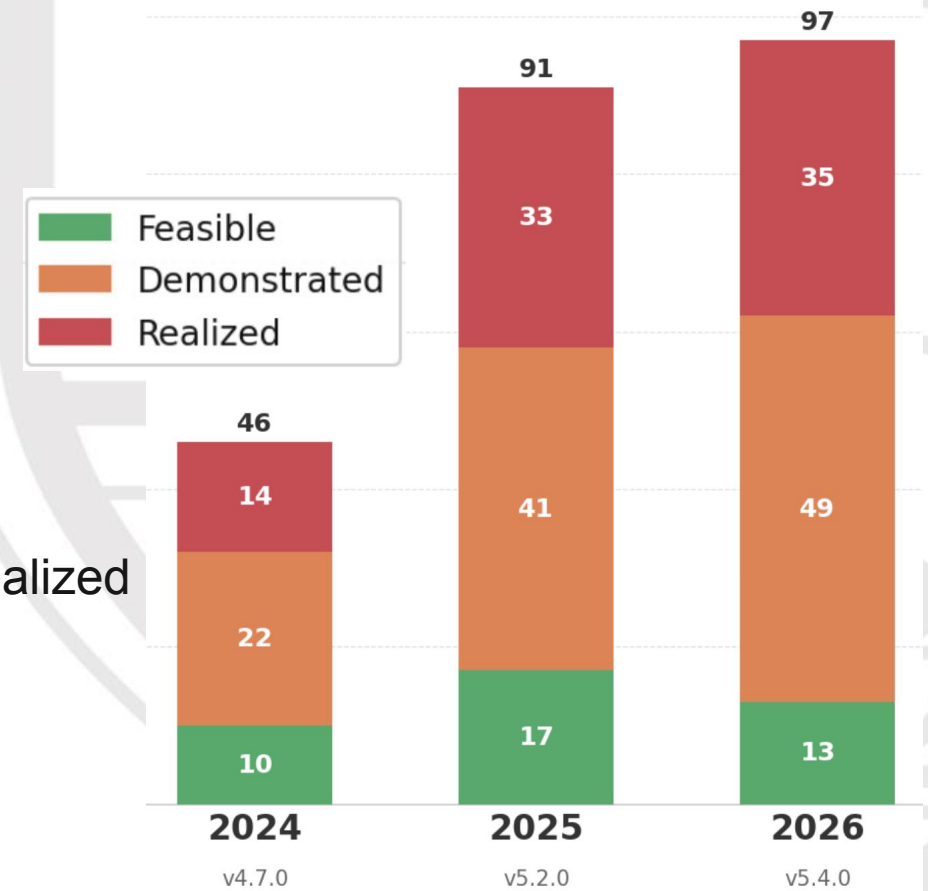
MITRE ATLAS

Knowledge base of adversarial tactics and techniques

- Evasion
- Poisoning
- Extraction
- Inference

Rapid growth and matriculation - Feasible / Demonstrated / Realized

- 2021 - 12 tactics with 36 techniques
- 2026 - 16 tactics with 97 techniques
 - 2025 - 45 new techniques
 - 2026^(*) - 10 new techniques (v5.6.1)



<https://atlas.mitre.org/matrices/ATLAS>

NIST AI RMF

Managing AI Risk across the lifecycle

- Govern
 - Establish culture, define roles, integrate
- Map
 - Identify context, categorize, document
- Measure
 - Analyze, evaluate, track
- Manage
 - Prioritize, respond, apply mitigation, communicate



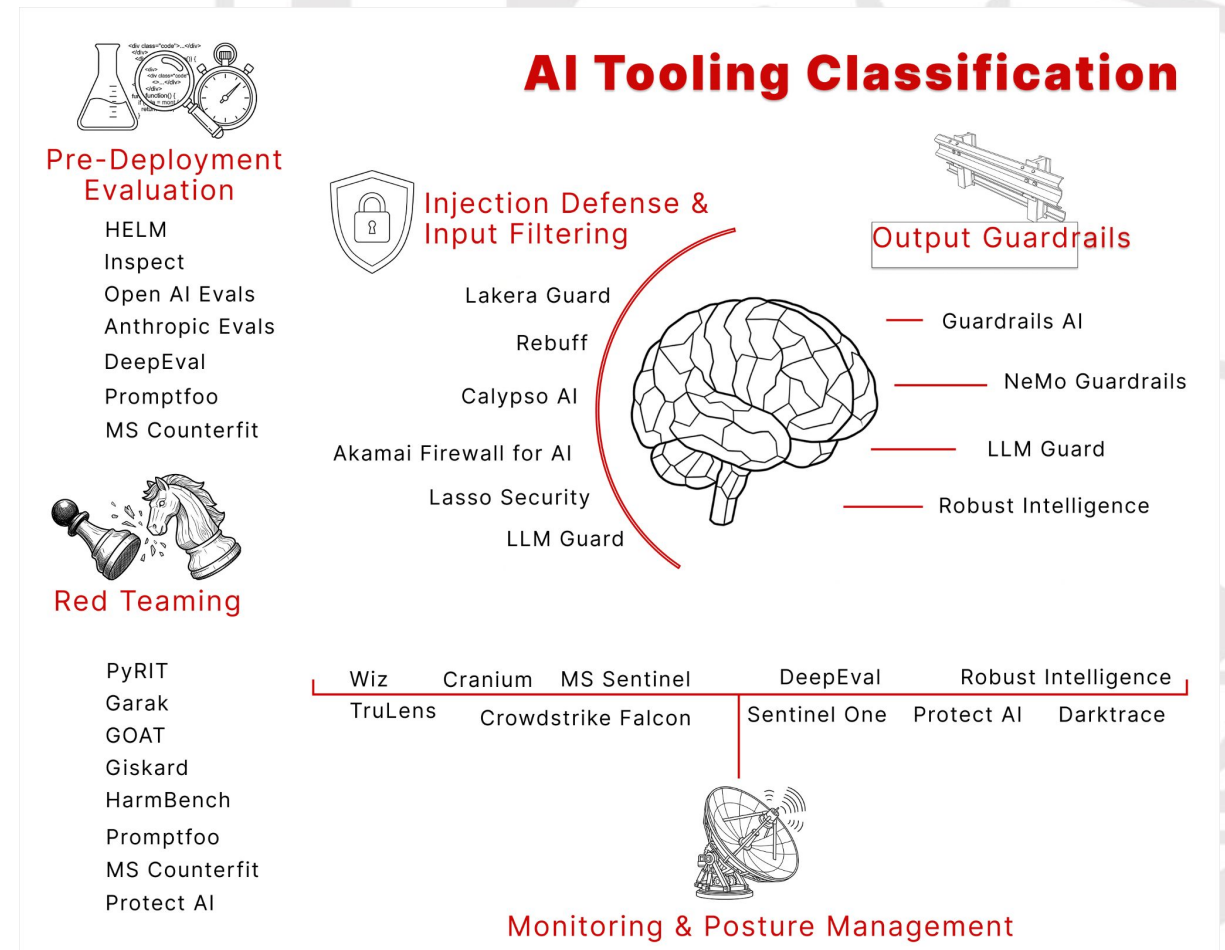
<https://www.nist.gov/itl/ai-risk-management-framework>

Results: Five Functional Categories of AI Security Tooling

TOOLING CATEGORIES

- Pre-Deployment Evaluation: benchmarks model behavior before release, including HELM and Inspect.
- Red Teaming: adversarial probing from static probe libraries such as Garak to adaptive agents such as GOAT.
- Input Defense: runtime interception of malicious prompts through tools such as Lakera Guard and Rebuff.
- Output Guardrails: response controls with NeMo Guardrails and Guardrails AI.
- Monitoring & Posture Management: production observability with TruLens, CrowdStrike, Darktrace, and similar platforms.

Taxonomy was validated against OWASP LLM Top 10 to confirm coverage across recognized threat classes.



Deployment/Evaluation Model

PURPOSE

- Help operations teams identify vulnerabilities faster and resolve them earlier.
- Use continuous AI-assisted red teaming to increase testing depth and reduce exposure.



Runthrough contents: predefined strategies, tactics, procedures, testing prompts, tool-selection guidance, escalation criteria, and remediation checkpoints.

Key Findings and Security Gaps

MAIN FINDINGS

- No single tool provides comprehensive GenAI security coverage; effective defense requires all five functional categories.
- Pre-deployment red teaming is the highest-leverage intervention because it catches vulnerabilities static evaluation and runtime monitoring can miss.
- Perimeter defense is insufficient because GenAI risk appears across data, model behavior, prompts, outputs, access, and production operations.

CRITICAL GAPS

- Training data poisoning is underserved by current tooling.
- Multimodal attack vectors are outpacing text-only input defenses.
- Prompt injection has no complete tooling-layer solution because transformer systems blur the boundary between instructions and data.

Bottom line: controls must be layered across the model lifecycle rather than added only at the application perimeter.

Recommended Layered Mitigation Strategy

BEFORE DEPLOYMENT

- Map system threats against OWASP LLM Top 10, MITRE ATLAS, and NIST AI RMF.
- Run pre-release evaluation, red team testing, and abuse-case validation.
- Document model limits, approved use cases, and high-risk data boundaries.

AT RUNTIME

- Apply prompt injection defenses, input validation, and least-privilege access.
- Use output guardrails for format, topic, sensitive data, and harmful content controls.
- Log high-risk interactions and route exceptions for human review.

ONGOING GOVERNANCE

- Monitor production posture and continuously retest as models, tools, and integrations change.
- Track tool coverage by category so gaps do not hide behind one vendor or one control.
- Update the playbook after incidents, model changes, and new threat intelligence.

Strategy: combine framework-guided threat analysis, layered defensive tooling, and governance that can adapt as attack vectors evolve.

Conclusion

Defending GenAI systems requires moving beyond point-in-time fixes toward continuous, layered security across the full deployment lifecycle.

- Pre-deployment red teaming is the highest-impact intervention for reducing GenAI risk before systems reach production.
- No single tool provides adequate coverage. Practical GenAI defense requires coordinated tooling across detection, validation, monitoring, and response.
- This project translates research findings into an actionable plan teams can embed into existing security workflows.

Organizations that treat GenAI security as a continuous practice, not a one-time assessment, will be meaningfully better positioned as the threat landscape evolves.

Questions?

